zer0Track

An AI agent that checks parcel handoff evidence and recommends whether a delivery is ready to accept or needs review. Track: Secure Logistics & Digital Trust — Handoff Trust Verifier | **Event:** GDEX x ANON x UTAR Agentic AI Cybersecurity Hackathon 2026 | **Team:** Don't Phish us - Raja, Win, Nour, Bhone, Kogu.

1. Problem and Users. A parcel scan, photo, or transfer code can be incomplete or inconsistent evidence of a handoff. zer0Track checks whether the parcel, authorised parties, and location agree before recommending acceptance, verification, or escalation — modelled on synthetic records; it does not assess GDEX's production security. Motivating incidents: a DOJ conviction of two men who won shipping contracts then never delivered (≥US$2M) [1]; a 2026 USPS OIG audit finding 358 packages improperly scanned, 85.5% marked "Delivered" without arriving [2]; Malaysia's Postal Forum calling courier-impersonation scams "an organised threat" (Jun 2026) [3]; and GDEX's own scam-alert warnings [4] — motivating context, not proof of a shared root cause. **Users:** GDEX delivery-hub supervisors and depot dispatchers — a triage aid, not a replacement for judgment.

2. Inputs and Trusted Data. Synthetic, EPCIS-inspired JSON: parcel/handoff IDs, timestamps, handler ID, location (accuracy/source); transfer-code status; manifest and authorisation records; handler-history; optional photo/receipt metadata as context only (not authenticated). An authenticated account must match the assigned handler/custodian; receiver authority comes from trusted records, never from incoming notes. Raw TAC/OTP secrets never enter prompts or audit displays. **Missing evidence is UNKNOWN, never a pass.**

3. Agent Workflow and Policy. (1) Validate against the manifest. (2) Run three mandatory checks, each PASS/FAIL/UNKNOWN — **parcel/code integrity**, **identity/authority**, **location**. (3) On UNKNOWN/conflicting, the system picks one allowlisted read-only lookup via a fixed deterministic mapping — never an LLM choice. (4) Explain: checks, evidence IDs, unresolved questions, recommended action. (5) Policy revalidates all mandatory checks before acceptance, independently of the LLM, which never selects tools or influences which runs.

Parcel/code	Identity	Location	Recommendation
PASS	PASS	PASS	Accept (policy revalidates first)
PASS	PASS	FAIL/UNKNOWN	Request verification; pending if unresolved
PASS	UNKNOWN / FAIL	Any	Hold — supervisor approval required
FAIL (e.g. replay)	Any	Any	Escalate — supervisor approval required
Any	Any	Tool failure/timeout	Operator review; never auto-accept

4. Safeguards. Transfer codes bound to parcel/transaction/receiver, single-use, atomically consumed on accept. Prompt-injection defence: untrusted notes, fixed read-only tool allowlist, schema-validated arguments, tested against real attack strings (fake "approved by supervisor", skip-the-check instructions, forged photo-caption text) — risk reduced, not eliminated. Holds/escalations/rejections need an authenticated supervisor who can disagree but not bypass checks. Audit: append-only, hash-linked, HMAC-signed log. **OWASP LLM Top 10** mitigated by design (LLM01 Prompt Injection, LLM02 Sensitive-Info Disclosure, LLM05 Improper Output Handling, LLM06 Excessive Agency — advisory only, LLM09 Misinformation, LLM10 Unbounded Consumption) [8]; **OWASP API Top 10** — A04 (rate limiting, §4a), A05 (docs/schema disabled in production) [9].

4a. Security hardening (built and merged after the initial design, before submission; all live and tested).

- **Dual-approval:** escalate/reject now requires two different authenticated supervisors; the same operator cannot confirm their own request — no single account can unilaterally escalate or reject.
- **Per-courier rate limiting:** 10 requests / rolling 60 s, enforced in SQLite across workers; the 11th returns HTTP 429.
- **External audit anchor:** a signed checkpoint (seq + hash + HMAC) stored outside the DB detects wholesale truncation a self-contained chain cannot; a simulated truncation passes without the anchor and correctly FAILs against it.
- **Live tamper demo:** a read-only dashboard control recomputes the chain in memory, showing exactly where verification breaks if any entry were edited.
- **Also:** display-only geofence view; staff-login lockout (5 attempts / 15 min) and hashed, 30-min session tokens; OTP-shaped digit redaction before the LLM/log/display; API docs disabled in production.

5. Demo and Evaluation. Demo (one journey, three runs): (1) guardhouse scan → delegation lookup finds a valid delegate → resolved; (2) same scan, no authorisation → pending, supervisor may hold; (3) replayed transfer code → blocked regardless of recommendation — plus the dual-approval and live tamper-evidence segments. **Evaluation:** 20 labelled synthetic cases across scan-only, rules-only, and rules+LLM, over three investigation-policy profiles. **Results (full merged system): 92.86% invalid-proof detection, 33.33% false-alert rate**, consistent across profiles (profiles tune investigator tool-call volume, not detection); the scan-only baseline detects only **7.14%** (19/20 unsupported acceptances) — the deliberately weak baseline. Under the loose profile, **3 of 20 cases made a genuine live Groq classifier call — confirmed against the provider's own usage counter, not a mock**; the classifier is advisory only and never changes the decision (on forged-note case SYN-S016 the "ignore identity checks" note provably does not move the outcome). **57 automated tests pass.** (Cases are reused across configurations — not independent samples; figures are not extrapolated to production.)

6. Limitations. A stolen-but-unused OTP can pass; spoofed coordinates can look consistent; collusion may defeat checks, and dual-approval does not stop two colluding supervisors. GPS error or ride-hailing delay can cause false mismatches — an alert requests verification, never accuses. Photos/signatures don't prove possession. Location data raises PDPA considerations; masking alone isn't compliance. Scalability/latency untested; no real-world pilot; operator alert-fatigue can weaken review.

7. Team. Bhone — Backend/policy (API, checks, policy, audit). Kogu — Agent/security (investigator, tool allowlist, injection tests). Raja — Data/evaluation (synthetic cases, comparison harness, metrics). Nour — Frontend/dashboard. Win — Integration/Pitch & Proposal/demo. Live pitch presenting is shared.

References. [1] DOJ, "Two Indian Nationals Found Guilty…" (29 Sep 2026) — justice.gov/usao-cdca [2] USPS OIG, Report 26-044-1-R26, Norfolk S&DC (9 Apr 2026) — uspsoig.gov [3] Bernama, "Postal Forum Urges Vigilance…" (23 Jun 2026) — bernama.com [4] GD Express Official Facebook, "SCAM ALERT" — facebook.com/GDEXOfficialPage [5] NIST SP 800-63B-4, *Digital Identity Guidelines* (2025) — pages.nist.gov [6] JPDP Malaysia, *Principles of Personal Data Protection* — pdp.gov.my [7] OWASP, *LLM01: Prompt Injection* (2025) — genai.owasp.org [8] OWASP, *Top 10 for LLM Applications* (2025) — genai.owasp.org [9] OWASP, *API Security Top 10* (2023) — owasp.org/API-Security